

Stemz HR Assistant

Confidential-Document Handling — Change & Logic Report

Generated: 2026-08-29 | Scope: RAG guardrail for confidential HR policies

1. Objective

Some HR policy documents (for example the **Executive Compensation Framework** and the **IT Team Declaration**) contain information that must never be disclosed to employees through the chatbot. The goal of this change is to make the assistant **detect** such documents and **refuse** to answer from them — redirecting the user to HR — without ever sending the confidential content to the language model.

2. Summary of Changes

Layer	File	What was added
Ingestion	apps/knowledge/services/parser.py	Reads <code>confidential: true</code> from each document's YAML frontmatter and stamps a boolean <code>confidential</code> flag onto every chunk of that document.
Guardrail	apps/rag/services/guardrail.py	New <code>is_confidential(chunk)</code> helper and a dedicated <code>CONFIDENTIAL_REFUSAL_MESSAGE</code> constant.
Request flow	apps/chatbot/views.py	A confidential guard that short-circuits the response before any LLM call, plus a defense-in-depth filter that strips confidential chunks from the context.
Content	knowledge/*.md	Sensitive documents marked with <code>confidential: true</code> in their frontmatter.

3. How It Works

3.1 Flagging at ingest time

When a markdown policy is parsed, its frontmatter is read and the confidential flag is normalised to a real boolean and attached to **every** chunk, so the retrieval pipeline never loses track of it:

```
base['confidential'] = str(metadata.get('confidential', '')).strip().lower() \
    in ('true', 'yes', '1')
```

Accepting `true`, `yes`, or `1` makes the flag tolerant of how the frontmatter is authored.

3.2 The guardrail helper

```
def is_confidential(chunk):
    return bool(chunk and chunk.get('confidential'))
```

A single source of truth for "is this chunk from a confidential document?", used in two places in the request flow.

3.3 Confidential guard in the request flow

After retrieval, the **top-ranked** chunk is inspected. If it belongs to a confidential document, the assistant streams a fixed refusal message, logs the exchange, and returns — **before** any call to the LLM:

```
if is_confidential(top_chunk):
    yield _sse({'type': 'token', 'text': CONFIDENTIAL_REFUSAL_MESSAGE})
    Message.objects.create(..., content=CONFIDENTIAL_REFUSAL_MESSAGE, ...)
    yield _sse({'type': 'done', 'confidence': 'refused'})
    return
```

3.4 Defense in depth

Even after the top-chunk guard passes, any lower-ranked confidential chunk that slipped into the results is removed before the context is handed to the model:

```
retrieved = [r for r in retrieved if not is_confidential(r['chunk'])]
```

4. Decision Flow

Step	Condition	Outcome
1. Retrieve	Top-k chunks fetched (cosine + reranker)	Continue
2. Confidential guard	Top chunk <code>confidential = true</code>	Refuse → redirect to HR (no LLM)
3. Confidence guard	Top rerank score < <code>SIM_THRESHOLD</code>	Generic refusal (no LLM)
4. Filter	Drop any remaining confidential chunks	Continue
5. Generate	Grounded prompt to Claude	Answer with Source citation

5. The Two Refusal Messages

Constant	When	Message
<code>CONFIDENTIAL_REFUSAL_MESSAGE</code>	Top chunk is from a confidential document	"This question relates to a confidential document that I'm not able to discuss. Please contact HR directly for assistance with this."
<code>REFUSAL_MESSAGE</code>	Top score below the similarity threshold (out of scope)	"I don't have that information in the current policy documents. I'll connect you with HR."

6. Why This Design

- **No leak to the model.** Confidential content is blocked before the LLM call, so it can never appear in a prompt or a generated answer.
- **Deterministic.** The refusal is a fixed string, not model output — it cannot be jailbroken or paraphrased into a disclosure.
- **Data-driven.** Marking a document confidential is a one-line frontmatter change; no code edits required to protect a new document.
- **Layered.** Top-chunk guard plus a context filter provides defense in depth.
- **Auditable.** Every refusal is written to the Message log with the retrieved titles and top score.

7. How to Test

Should trigger the **CONFIDENTIAL** refusal

- What are the salary bands for the CEO and CFO?
- How is the executive bonus structure calculated?
- What is the equity grant and vesting schedule for executives?
- What severance and change-of-control terms do executives get?

Should still be answered (non-confidential confidentiality policies)

- What are my confidentiality obligations at Stemz? (**NDA**)
- How long do post-employment confidentiality obligations last?
- How must I handle visa applicant data?

Note: To protect a new document, add `confidential: true` to its frontmatter and re-run `python manage.py ingest_docs`. The flag only takes effect after re-ingestion.